ISO 27001

Seguridad de la Información – ISO 27001

Procedimiento Gestión de Acceso

Esteban Chamblat Rojas

TABLA DE CONTENIDO

1. **OBJETIVO Y CAMPO DE APLICACIÓN**
2. **REFERENCIAS DEL MANUAL**
3. **CONTROLES TECNOLÓGICOS**
    - 3.1 Dispositivos finales de usuario
    - 3.2 Privilegios de acceso restringidos
    - 3.3 Restricción de acceso a la información
    - 3.4 Acceso a códigos fuente
    - 3.5 Autenticación segura
    - 3.6 Gestión de capacidad
    - 3.7 Protección contra malware
    - 3.8 Gestión de vulnerabilidades técnicas
    - 3.9 Gestión de la configuración
    - 3.10 Eliminación de información
    - 3.11 Enmascaramiento de datos
    - 3.12 Prevención de fuga de datos
    - 3.13 Copias de seguridad (Backup)
    - 3.14 Disponibilidad de las instalaciones de TI
    - 3.15 Registro de eventos (Logging)
    - 3.16 Actividades de monitoreo
    - 3.17 Sincronización de relojes
    - 3.18 Uso de programas de utilidad con privilegios
    - 3.19 Instalación de software en sistemas operativos
    - 3.20 Seguridad en redes
    - 3.21 Seguridad en servicios de red

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

- 3.22 Segregación de redes
- 3.23 Filtrado web
- 3.24 Uso de criptografía

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Seguridad de la Información – ISO 27001

Información del Documento	Detalle
Autor del Documento	Esteban Chamblat
Fecha de Creación	18/01/2025
Clasificación	Uso Interno / Confidencial

HISTORIA DE VERSIONES

Versión	Fecha	Descripción	Autor
1.0	**14/05/2025**	**Creación de documento**	**Esteban Chamblat**

1. OBJETIVO Y CAMPO DE APLICACIÓN

Establecer las directrices tecnológicas que **Pepito paga doble** utiliza para proteger sus activos digitales. Este manual define la configuración y el mantenimiento del stack oficial (**Proxmox VE, Docker Swarm, Rocky Linux, pfSense y PostgreSQL**) para garantizar la resiliencia operativa y la seguridad de la información.

2. REFERENCIAS DEL MANUAL

- **ISO 27001:2022:** Sistemas de Gestión de la Seguridad de la Información.
- **ISO 27002:2022:** Controles de Seguridad.

3. CONTROLES TECNOLÓGICOS

3.1 Dispositivos finales de usuario

La información en dispositivos finales (laptops, móviles) debe estar protegida contra pérdida o exposición. Es obligatorio el uso de cifrado de disco y bloqueos automáticos de sesión.

3.2 Privilegios de acceso restringidos

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Se aplica el principio de mínimo privilegio. El acceso a las consolas de administración de **Proxmox VE** y **Docker Swarm** está limitado al personal de infraestructura autorizado.

3.3 Restricción de acceso a la información

El acceso a aplicaciones y datos se otorga según la función laboral. En **PostgreSQL**, los permisos se manejan por roles específicos, evitando el uso de la cuenta superuser en aplicaciones.

3.4 Acceso a códigos fuente

El código fuente de las aplicaciones de **Pepito paga doble** se almacena en repositorios privados con control de acceso estricto y trazabilidad de cambios.

3.5 Autenticación segura

Se requiere autenticación multifactor (**MFA**) para todo acceso externo a través de la VPN gestionada por **pfSense** y para el acceso al directorio central **OpenTux**.

3.6 Gestión de capacidad

Se monitorea el uso de recursos (CPU, RAM, Almacenamiento) en los nodos de **Proxmox VE**. Se establecen alertas preventivas cuando el consumo supera el 80% de la capacidad.

3.7 Protección contra malware

Todos los sistemas operativos **Rocky Linux** y estaciones de trabajo deben contar con software de protección activo y actualizado.

3.8 Gestión de vulnerabilidades técnicas

Se realizan escaneos periódicos. Los parches críticos en el stack de servidores deben aplicarse en un plazo no mayor a 15 días tras su liberación.

3.9 Gestión de la configuración

Las configuraciones de red en **pfSense** y los archivos de despliegue de **Docker Swarm** deben estar documentados y versionados.

3.10 Eliminación de información

Cuando un activo de almacenamiento cumple su vida útil, se procede al borrado seguro o destrucción física para evitar la recuperación de datos.

3.11 Enmascaramiento de datos

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

En entornos de desarrollo y pruebas, los datos sensibles de **PostgreSQL** deben ser enmascarados o anonimizados.

3.12 Prevención de fuga de datos (DLP)

Se aplican medidas para detectar y prevenir la extracción no autorizada de información confidencial hacia redes externas.

3.13 Copias de seguridad (Backup)

Se mantienen respaldos periódicos de las bases de datos y configuraciones. Las pruebas de restauración se ejecutan semestralmente para garantizar la integridad de los datos.

3.14 Disponibilidad de las instalaciones de TI

La infraestructura en **Proxmox VE** está diseñada con alta disponibilidad para asegurar que los servicios críticos permanezcan operativos ante fallos de hardware.

3.15 Registro de eventos (Logging)

Se activan logs de auditoría en todos los sistemas. Estos registros se centralizan para su análisis y protección contra alteraciones.

3.16 Actividades de monitoreo

Se supervisa el tráfico de red y el comportamiento de los contenedores en **Docker Swarm** para detectar anomalías en tiempo real.

3.17 Sincronización de relojes

Todos los servidores y dispositivos de red deben sincronizar su hora con el servidor NTP institucional para garantizar la precisión de los logs.

3.18 Uso de programas de utilidad con privilegios

El uso de herramientas de diagnóstico o administración con privilegios elevados debe ser restringido y supervisado.

3.19 Instalación de software en sistemas operativos

Solo se permite la instalación de software autorizado y verificado en los servidores **Rocky Linux**.

3.20 Seguridad en redes

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Los perímetros de red están protegidos por **pfSense**, configurado con reglas de denegación por defecto.

3.21 Seguridad en servicios de red

Se aseguran todos los servicios de red (SSH, HTTPS) mediante el uso de protocolos cifrados y la desactivación de funciones innecesarias.

3.22 Segregación de redes

Se utilizan VLANs y redes virtuales para separar el tráfico de gestión, producción y bases de datos, minimizando el radio de impacto ante incidentes.

3.23 Filtrado web

Se bloquea el acceso a sitios web maliciosos o no relacionados con la actividad laboral mediante los servicios de filtrado de **pfSense**.

3.24 Uso de criptografía

Toda información sensible en tránsito o en reposo dentro del stack corporativo debe estar cifrada utilizando algoritmos robustos y certificados vigentes.

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*